

Parent Portal & Tổng hợp Backend

Role đúng chưa đủ — phải kiểm tra ownership dữ liệu

MỤC TIÊU BUỔI HỌC

- Kiểm soát truy cập theo ownership dữ liệu
- Tổng hợp invoice, notification, learning result về 1 dashboard
- Nhìn lại kiến trúc hoàn chỉnh của toàn hệ thống

1

Mở File

Xem đúng file lỗi
trước khi code

2

Workflow

Hiểu bài toán &
luồng dữ liệu

3

Demo API

Chạy request theo
thứ tự trên Postman

4

Bài tập

Mở rộng từ demo
sinh viên tự làm

CÂU HỎI DẪN NHẬP

- Role PARENT có đủ để xem mọi student không? Tại sao không?
- Ở parent portal, dữ liệu nào nên gom về một lần gọi API?

1

ParentPortalService.java

→ Gom dữ liệu dashboard cho phụ huynh

2

ParentPortalController.java

→ Endpoint GET /parent/dashboard

3

ParentDashboardResponse.java

→ Cấu trúc response tổng hợp

4

SecurityConfig.java

→ Bảo vệ route — chỉ PARENT được truy cập

5

AuthService.java

→ Đọc current user từ JWT token

1

Phụ huynh login → lấy JWT token

SecurityConfig chặn route /parent/** → phải có token hợp lệ

2

Lấy parentId từ current user

AuthService.getCurrentUser() → trích parentId từ token

3

Tải danh sách student thuộc parentId đó

Chỉ student của parent này — không phải tất cả student

4

Ghép invoice + notification + learning result

ParentPortalService gọi nhiều repository trong 1 method

5

Trả ParentDashboardResponse tổng hợp

Frontend chỉ cần 1 request để render toàn bộ dashboard



LƯU Ý QUAN TRỌNG



Authorization ≠ Authentication

Role PARENT = xác nhận bạn là phụ huynh.

Nhưng phải kiểm tra thêm: student này có phải con của parent hiện tại không?

Đây là authorization theo OWNERSHIP.

1

① Tạo student + parent

Module Student

2

② Mở class và enroll student

Module Class + Enrollment

3

③ Điểm danh + gửi thông báo

Module Attendance + Notification

4

④ Tạo invoice + áp khuyến mãi

Module Billing (Buổi 10)

5

⑤ Thu học phí + cập nhật công nợ

Module Payment (Buổi 11)

6

⑥ Parent xem toàn bộ trên dashboard

Module Parent Portal (Buổi 12)



LƯU Ý QUAN TRỌNG

🔍 Đây là luồng hoàn chỉnh của toàn hệ thống YOEDU.

Mỗi buổi học là 1 mảnh ghép.

Buổi 12 là nơi toàn bộ mảnh ghép lại thành bức tranh toàn cảnh.

ENTITY / ENUM

Mô tả cấu trúc dữ liệu

- **Parent**
- **Student**
- **Notification**
- **TuitionInvoice**
- **LearningResult**

SERVICE

Giữ toàn bộ nghiệp vụ

- **ParentPortalService**

CONTROLLER

Mở REST API ra ngoài

- **ParentPortalController**

💡 ParentPortalService phải kiểm tra ownership trước khi trả dữ liệu. Nếu parentId trong token không khớp → trả 403 Forbidden, không phải 404.

GET

`/api/parent/dashboard`

Dashboard tổng hợp: invoice + notify + kết quả học

GET

`/api/parent/students/{studentId}`

Chi tiết 1 học sinh (phải là con của parent đó)

▶ TRÌNH TỰ DEMO

- ① Chạy request thành công một lần đầu
- ② Sửa dữ liệu để thấy điểm thất bại
- ③ Xem kết quả trong DB và response DTO

👁️ QUAN SÁT KHI DEMO

- ① JWT token có đúng role PARENT và parentId không?
- ② ParentPortalService có check ownership student không?
- ③ Response đủ field để React render dashboard không?



NHỮNG ĐIỀU BẮT BUỘC PHẢI ĐÚNG



Role đúng chưa đủ — phải kiểm tra ownership dữ liệu (student thuộc parent nào?)



Dashboard nên gom dữ liệu trong ít DB query nhất có thể



Response format phải đủ cho frontend React dùng ngay (không thiếu field)



Tổng kết lại toàn bộ pattern đã dùng trong 12 buổi backend



BÀI TẬP GIAO CUỐI BUỔI

1. Hoàn thiện mini flow: login → class → enroll → attendance → invoice → payment → parent dashboard
2. Chuẩn bị source nền sạch để kết nối với React (tuần sau)
3. Rà lại toàn bộ validation, security config và response format



SAU BUỔI NÀY SINH VIÊN CÓ THỂ:

- ✓ Ghép toàn bộ backend thành luồng phục vụ phụ huynh
- ✓ Hiểu authorization theo ownership dữ liệu
- ✓ Sẵn sàng kết nối frontend React ở module tiếp theo



THÔNG điệp CHỐT BUỔI

"Backend là nền. Hiểu đúng từng tầng — Entity → Service → Controller — rồi React chỉ là lớp áo bên ngoài."